

# VAPT Security Report

Target: clinic-production-83e1.up.railway.app  
Scan Time: 2026-09-14 12:48:44  
Report Generated: 2026-09-14 13:12:18

**Host: 69.46.46.89 (clinic-production-83e1.up.railway.app)**

State: up

## Protocol: TCP

| Port | State | Service | Product | Version |
|------|-------|---------|---------|---------|
| 80   | open  | http    | Pingora | -       |
| 443  | open  | https   | Pingora | -       |

# AI Security Analysis

Here is an educational security analysis of the provided scan output, focusing on general risk assessment and standard system hardening practices.

---

## 1. Summary of Open Ports & General Risks

- \* \*\*Port 22 (SSH - OpenSSH 6.6.1p1)\*\*  
\* \*\*Function:\*\* Used for secure remote administration and command-line access.  
\* \*\*Associated Risk:\*\* Publicly accessible SSH ports are frequent targets for automated brute-force attacks. Additionally, older software versions (such as OpenSSH 6.6.1p1, originally released around 2014) may contain known security vulnerabilities if missing security patches.
- \* \*\*Port 80 (HTTP - Apache httpd 2.4.7)\*\*  
\* \*\*Function:\*\* Serves web traffic over unencrypted HTTP.  
\* \*\*Associated Risk:\*\* Plaintext HTTP traffic can be intercepted or modified by network eavesdroppers. Running older versions of Apache web servers increases the risk of unpatched vulnerabilities affecting web applications.
- \* \*\*Port 9929 (nping-echo)\*\*  
\* \*\*Function:\*\* Used by Nmap's `nping` utility for network testing and measurement.  
\* \*\*Associated Risk:\*\* Running specialized network tools publicly increases the host's exposed attack surface unnecessarily if not actively needed for operations.
- \* \*\*Port 31337 (tcpwrapped)\*\*  
\* \*\*Function:\*\* The term `tcpwrapped` indicates that the service accepted a TCP connection but closed it immediately (often due to TCP Wrappers or firewall access controls).  
\* \*\*Associated Risk:\*\* While the service is protected from full interaction, exposing non-standard or legacy ports (31337 historically associated with default test services) can signal running or hidden services to network scanners.

---

## 2. Severity Classification

| Finding                                  | Severity Level     | Rationale                                                                                                                                                                                           |
|------------------------------------------|--------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| :--   :--   :--                          |                    |                                                                                                                                                                                                     |
| **Outdated Software Versions**           | **MEDIUM to HIGH** | Running older software releases (e.g., legacy OpenSSH/Apache) exposes systems to known CVEs. Severity depends on whether security patches have been backported by the operating system maintainers. |
| **Unencrypted Web Traffic (Port 80)**    | **MEDIUM**         | Standard HTTP lacks transport layer security (TLS), leaving sensitive data vulnerable to interception on local networks.                                                                            |
| **Exposed SSH Service (Port 22)**        | **LOW to MEDIUM**  | SSH itself is secure by design, but exposure to the public internet invites automated login attempts.                                                                                               |
| **Unnecessary Open Ports (9929, 31337)** | **LOW**            | Extraneous open ports expand the system's attack surface without providing essential business utility.                                                                                              |

---

## 3. General Defensive Remediation Steps

### A. Software Maintenance & Patch Management

- \* \*\*Update System Packages:\*\* Regularly update software components (OpenSSH, Apache, operating system packages) to actively supported versions to receive security updates.
- \* \*\*Audit Backported Patches:\*\* On Linux distributions (like Ubuntu), check if security updates have been backported to older version strings before relying solely on version numbers.

## B. SSH Hardening

- \* \*\*Disable Password Authentication:\*\* Configure `/etc/ssh/sshd_config` to require public key authentication (`PasswordAuthentication no`).
- \* \*\*Restrict Access:\*\* Use network firewalls or cloud security groups to restrict SSH access to trusted IP addresses or VPN ranges only.
- \* \*\*Disable Root Login:\*\* Set `PermitRootLogin no` in the SSH configuration.

## C. Web Traffic Encryption

- \* \*\*Implement TLS/HTTPS:\*\* Configure the web server to use HTTPS (Port 443) using modern TLS certificates (e.g., via Let's Encrypt).
- \* \*\*Redirect HTTP Traffic:\*\* Set up an automatic HTTP-to-HTTPS redirect (301 Redirect) so unencrypted connections are upgraded automatically.

## D. Network Minimization (Attack Surface Reduction)

- \* \*\*Close Unused Ports:\*\* Stop and disable services that are not strictly required for operations (e.g., `nping-echo`).
- \* \*\*Enforce Firewall Policies:\*\* Implement default-deny firewall rules (via `ufw`, `iptables`, or cloud firewalls) to block traffic to all ports except those explicitly required for public services.